École Nationale Supérieure Polytechnique de Yaoundé
UE : GES/062

CHARTE DE GOUVERNANCE

Matrice RACI — Gestion des incidents critiques
Entreprise LiZbiZ

Réalisé par : BAALAWE LIONEL JOSSELIN
Matricule : 24P822
Encadrant : Thierry MINKA
Date : Mars 2026

Table des matières

1 Contexte et problématique **2**
1.1 Situation actuelle de LiZbiZ 2
1.2 Objectifs de ce document 2

2 Charte de gouvernance — Rôle du RSSI **3**
2.1 Définition du RSSI 3
2.2 Positionnement hiérarchique 3
2.3 Missions du RSSI 4
2.4 Ce que le RSSI N'est PAS 4
2.5 Instances de gouvernance à créer 5

3 Matrice RACI — Gestion des incidents critiques **6**
3.1 Rappel des concepts RACI 6
3.2 Définition d'un incident critique 6
3.3 Acteurs impliqués 7
3.4 Matrice RACI complète 7

4 Plan d'actions prioritaires **9**

5 Conclusion **10**

Chapitre 1

Contexte et problématique

1.1 Situation actuelle de LiZbiZ

LiZbiZ est une entreprise de commerce en ligne ayant connu une croissance rapide, passant de 20 à 150 employés en deux ans. Si cette croissance est une réussite commerciale, elle a engendré un vide organisationnel critique : la structure de gouvernance de la sécurité du système d'information n'a pas évolué en conséquence.

Problème identifié

Trois problèmes structurels majeurs ont été identifiés lors de l'audit de la structure actuelle :

1. **Conflit d'intérêt :** La DSI (Sophie M.) cumule les rôles de DSI et de RSSI par défaut. Elle est à la fois juge et partie — elle crée les accès et les valide elle-même. Le contrôle interne est inexistant.
2. **Manque de visibilité :** Aucun Comité de Sécurité n'existe. La Direction Générale (Jean-Pierre L.) n'est pas informée des risques techniques et ne peut donc pas prendre de décisions éclairées.
3. **Absence de RACI formel :** Les processus de sécurité sont gérés à l'oral, ce qui engendre des oublis, des erreurs et une impossibilité de tracer les responsabilités en cas d'incident.

1.2 Objectifs de ce document

Ce document constitue la réponse à la mission confiée dans le cadre du TP (section 3.4.3 du cours) : proposer, pour le prochain Comité de Direction, une charte de gouvernance simple définissant clairement le rôle du futur RSSI et une matrice RACI pour la gestion des incidents critiques.

Chapitre 2

Charte de gouvernance — Rôle du RSSI

2.1 Définition du RSSI

Définition

Le **RSSI** (Responsable de la Sécurité des Systèmes d'Information) est le point focal de la sécurité au sein de l'entreprise. Son rôle est de définir la politique de sécurité, de sensibiliser les équipes et de superviser la mise en œuvre des mesures. Il pilote le risque — il n'est pas nécessairement un technicien pur. Il rapporte directement à la Direction Générale.

2.2 Positionnement hiérarchique

Le RSSI doit être rattaché **directement au PDG** (Jean-Pierre L.) et non à la DSI. Ce positionnement est fondamental pour trois raisons :

- Garantir son **indépendance** vis-à-vis de la DSI
- Éliminer le **conflit d'intérêt** actuel (Sophie M. juge et partie)
- Lui donner l'**autorité** nécessaire pour imposer des mesures de sécurité, y compris à la DSI

Table 2.1 – Comparaison situation actuelle vs situation cible

Situation ACTUELLE (à corriger)	Situation CIBLE (charte proposée)
PDG (Jean-Pierre L.) ↪ DSI (Sophie M.) ← RSSI *par défaut* ↪ Équipe technique **Poste RSSI : VACANT**	PDG (Jean-Pierre L.) ⊢ DSI (Sophie M.) ↪ Équipe technique ⊢ **RSSI (à recruter)** ↪ DPO

2.3 Missions du RSSI

Les missions du RSSI couvrent quatre domaines essentiels :

Table 2.2 – Missions du RSSI chez LiZbiZ

Domaine	Mission	Description
Stratégie	Politique de sécurité	Rédiger, maintenir et faire approuver la PSSI par la Direction
Stratégie	Gestion des risques	Identifier, évaluer et traiter les risques liés au SI — produire un registre des risques
Opérationnel	Supervision incidents	Coordonner la réponse aux incidents critiques — activer la cellule de crise
Opérationnel	Contrôle des accès	Valider les droits d'accès critiques — être le « A » (Accountable) du RACI des accès
Conformité	RGPD / PCI-DSS / LPM	Veiller au respect des obligations réglementaires en lien avec le DPO
Humain	Sensibilisation	Former les 150 employés aux bonnes pratiques — phishing, mots de passe
Reporting	Rapport au COMEX	Présenter mensuellement un tableau de bord sécurité au PDG
Gouvernance	Comité de Sécurité	Animer une réunion mensuelle avec DSI, DPO et représentants métiers

2.4 Ce que le RSSI N'est PAS

Information

Le RSSI n'est pas un technicien pur. Il **pilote le risque**, il ne fait pas forcément la technique lui-même. Il ne remplace pas la DSI — il la contrôle et la conseille. La différence fondamentale est celle entre la **gouvernance** (le « Pourquoi » et le « Comment ») et le **management** (le « Quoi » et le « Quand »).

Table 2.3 – Périmètre d'action du RSSI

Le RSSI FAIT	Le RSSI NE FAIT PAS
Définir la politique de filtrage du FortiGate	× Configurer lui-même le FortiGate
Valider le processus de mise à jour	× Appliquer les patches lui-même
Définir la classification des données	× Chiffrer les disques lui-même
Analyser l'impact business d'un incident	× Résoudre techniquement l'incident
Décider des investissements sécurité	× Acheter et installer le matériel

2.5 Instances de gouvernance à créer

Table 2.4 – Instances de gouvernance proposées

Instance	Fréquence	Participants	Objectif
COMEX	Trimestriel	PDG, DSI, RSSI, DAF	Valider les budgets sécurité, arbitrer les risques majeurs
Comité de Sécurité	Mensuel	RSSI, DSI, DPO, Métiers	Suivi des incidents, avancement projets, indicateurs
Cellule de Crise	Sur incident	PDG, RSSI, DSI, DPO	Gérer un incident majeur — décisions rapides

Chapitre 3

Matrice RACI — Gestion des incidents critiques

3.1 Rappel des concepts RACI

Définition

La matrice **RACI** est un outil de répartition des rôles qui clarifie **qui fait quoi** dans un processus :

- **R** (*Responsible*) : Réalise concrètement la tâche. Plusieurs R sont possibles par activité.
- **A** (*Accountable*) : Décideur unique et redevable du résultat. **Un seul A par activité** — il ne peut pas déléguer sa redevabilité.
- **C** (*Consulted*) : Expert sollicité avant la décision. Communication bidirectionnelle.
- **I** (*Informed*) : Informé du résultat uniquement. Communication unidirectionnelle.

Cas pratique — Accountability chez LiZbiZ

Chez LiZbiZ, si une fuite de données massive survient, le Directeur Général (Jean-Pierre L.) est **redevable** (Accountable) devant les actionnaires, même s'il n'a pas techniquement causé l'incident. Il ne peut pas dire « ce n'est pas ma faute, c'est celle de l'informaticien ».

3.2 Définition d'un incident critique

Un **incident critique** chez LiZbiZ est tout événement affectant la disponibilité, l'intégrité ou la confidentialité des systèmes essentiels. Sont concernés en priorité :

- **ERP Odoo v15** — gestion des stocks, ventes et comptabilité

- **Base de données PostgreSQL 13** — données clients et commandes
- **Site e-commerce Magento 2** — interface publique et transactions
- **Active Directory (Windows Server 2019)** — authentification employés
- **Scanners RFID (50 unités)** — logistique critique

3.3 Acteurs impliqués

Table 3.1 – Acteurs de la gestion des incidents critiques

Acteur	Rôle dans la gestion d'incident
PDG (Jean-Pierre L.)	Décideur stratégique ultime — arbitre les décisions à fort impact business
RSSI (à recruter)	Chef d'orchestre de la réponse — coordonne tous les acteurs
DSI (Sophie M.)	Pilote technique — supervise l'équipe technique
Équipe Technique	Exécute les actions techniques (isolation, restauration, forensique)
DPO	Garant RGPD — notifie la CNIL si des données personnelles sont concernées
Représentants Métiers	Évaluent l'impact opérationnel — valident le retour à la normale

3.4 Matrice RACI complète

Point critique

Règle fondamentale : chaque ligne doit comporter exactement **un seul A**. Si une ligne a deux A ou zéro A, la gouvernance est défaillante. C'est précisément le problème actuel chez LiZbiZ où le poste de RSSI est vacant.

Table 3.2: Matrice RACI — Gestion des incidents critiques chez LiZbiZ

Activité	PDG	RSSI	DSI	Éq. Tech.	DPO	Métiers
Détection et signalement de l'incident	I	I	I	**R**	I	**R**
Qualification et évaluation de la gravité	I	**A**	**C**	**R**	**C**	**C**
Décision d'activation de la cellule de crise	**A**	**R**	**C**	I	I	I
Confinement et isolation des systèmes	I	**A**	**C**	**R**	I	I

Suite page suivante...

Activité	PDG	RSSI	DSI	Éq. Tech.	DPO	Métiers
Communication interne (employés)	C	R	I	I	C	A
Communication externe (clients, presse)	A	C	I	I	R	C
Notification CNIL (données personnelles)	I	C	I	I	A	I
Analyse forensique et investigation	I	A	C	R	C	I
Restauration des systèmes	I	A	R	R	I	C
Rédaction du rapport post-incident	I	R	C	C	C	I
Validation du retour à la normale	A	R	C	C	I	C
Mise à jour du plan de réponse	I	R	C	C	I	I

Table 3.3 – Légende de la matrice RACI

Code	Signification
R	**Responsible** — Réalise concrètement la tâche. Plusieurs R possibles.
A	**Accountable** — Décideur unique redevable du résultat. **Un seul A par ligne.** Ne peut pas déléguer sa redevabilité.
C	**Consulted** — Expert sollicité avant la décision. Communication bidirectionnelle.
I	**Informed** — Informé du résultat uniquement. Communication unidirectionnelle.

Chapitre 4

Plan d'actions prioritaires

Pour mettre en œuvre cette charte, cinq actions sont à engager immédiatement par ordre de priorité :

Table 4.1 – Plan d'actions prioritaires

Prio.	Action	Description	Resp.	Délai
1	Recruter le RSSI	Nommer un RSSI indépendant rattaché au PDG — mettre fin à la double casquette DSI/RSSI	PDG	Immédiat
2	Créer le Comité Sécurité	Organiser une réunion mensuelle RSSI + DSI + DPO + Métiers	RSSI + PDG	1 mois
3	Formaliser le RACI accès	Déployer la matrice RACI pour la gestion des comptes AD et droits ERP	RSSI + DSI	1 mois
4	Nommer un DPO	LiZbiZ traite des données sensibles (RGPD + PCI-DSS) — DPO indispensable	PDG + DRH	2 mois
5	Sensibiliser la Direction	Présenter au COMEX un tableau de bord des risques cyber	RSSI	2 mois

Chapitre 5

Conclusion

La situation actuelle de LiZbiZ présente des risques structurels sérieux liés à l'absence d'une gouvernance de sécurité formalisée. La croissance rapide de l'entreprise a créé un vide organisationnel que cette charte propose de combler en deux livrables complémentaires.

Premier livrable — La charte du RSSI : elle définit le positionnement hiérarchique (rattachement direct au PDG), les huit missions clés, et distingue clairement ce que le RSSI fait de ce qu'il ne fait pas. Elle établit également les trois instances de gouvernance nécessaires : le COMEX trimestriel, le Comité de Sécurité mensuel et la Cellule de Crise sur incident.

Deuxième livrable — La matrice RACI : elle clarifie, pour chacune des douze activités de la gestion d'un incident critique, qui réalise, qui décide, qui est consulté et qui est informé. Elle respecte la règle fondamentale d'un unique Accountable par activité, garantissant ainsi une chaîne de responsabilité sans ambiguïté.

Solution proposée

Message clé : la gouvernance de la sécurité n'est pas un frein au business — c'est une condition de sa pérennité. Un incident non maîtrisé (fuite de données clients, paralysie de l'ERP Odoo, compromission du site Magento) coûte infiniment plus cher que le salaire d'un RSSI et la mise en place de ces instances de gouvernance.

Fait à [Ville], le Mars 2026

Signature : _____

BAALAWE LIONEL JOSSELIN